

CENTRO UNIVERSITÁRIO MARTHA FALCÃO WYDEN
CURSO DE ANÁLISE E DESENVOLVIMENTO DE SISTEMAS
DISCIPLINA: INTRODUÇÃO À SEGURANÇA DA INFORMAÇÃO
PROFESSOR: RANYERE NEY OSÓRIO LIMA

SIMULADO ENADE - 10 QUESTÕES DISCURSIVAS

Alunos: Cauê Lima, Juan Valente, Felipe Costa, Jefferson e Lucas Gabriel
Turma: 3001
Período: 2026.2

QUESTÃO 1 - Cenário hospitalar

Um hospital sofre um ataque onde prontuários são criptografados e o acesso é bloqueado. Qual princípio da Tríade CID foi o alvo direto e qual a implicação imediata para o atendimento?

Resposta:

A resposta é Disponibilidade. O dado não vazou e nem foi alterado, ele continua lá do mesmo jeito, só que trancado. Confidencialidade e Integridade continuam de pé, quem caiu foi a Disponibilidade.

Na prática o hospital volta pro papel. O médico atende sem ver o histórico, sem saber se o paciente tem alergia e sem saber que remédio ele já toma. Isso não é só prejuízo de dinheiro, é risco pro paciente mesmo, cirurgia que adia e paciente que precisa ser transferido.

Vale lembrar que se o atacante copiou os dados antes de criptografar aí a Confidencialidade cai junto. Mas o alvo do bloqueio em si é a Disponibilidade.

Fundamentação: ISO/IEC 27001; A.5.29 segurança durante interrupção; A.5.30 prontidão de TIC para continuidade

QUESTÃO 2 - LGPD e consentimento

Uma empresa compartilha dados de clientes com parceiros sem aviso prévio. Segundo a LGPD, quais direitos do titular foram violados e qual a base legal necessária para tal ação?

Resposta:

O que a empresa violou foi a transparência. O cliente tinha o direito de saber pra quem os dados dele estavam indo e não foi avisado.

Os direitos que caíram são o de informação sobre o uso compartilhado, que está no art. 18, VII, o de livre acesso e o de se opor ao tratamento. Junto com isso caem os princípios da finalidade e da transparência do art. 6º, porque compartilhar com parceiro é um tratamento novo e não é continuação automática do que o cliente autorizou antes.

Pra fazer isso do jeito certo a empresa precisava de consentimento específico e destacado pra esse compartilhamento, art. 7º, I junto com o art. 8º. Dá pra usar legítimo interesse em alguns casos, art. 7º, IX, mas aí tem que fazer o teste de balanceamento e avisar o titular do mesmo jeito. E se for dado sensível nem isso vale, só consentimento específico, art. 11.

Fundamentação: LGPD; art. 6º, 7º, 8º, 11 e 18, VII; ISO/IEC 27002; 5.34 privacidade e proteção de dados pessoais

QUESTÃO 3 - Engenharia social

Um funcionário fornece sua senha por telefone a um suposto técnico de TI. Analise a falha sob a ótica do elo mais fraco da segurança e proponha uma medida preventiva não tecnológica.

Resposta:

Nenhum controle técnico falhou aqui. O firewall, o antivírus e a criptografia continuaram funcionando normal. Quem falhou foi a pessoa, e é por isso que a gente fala que o usuário é o elo mais fraco.

O atacante não quebrou nada, ele só pediu a senha e entrou pela porta da frente com credencial válida. Enganar gente sai muito mais barato do que tentar quebrar uma criptografia.

Como medida não tecnológica eu proponho treinamento de conscientização periódico, junto com uma política escrita dizendo que a TI nunca pede senha, e o procedimento de desligar o telefone e ligar de volta no ramal oficial antes de passar qualquer informação.

Uma coisa que muita empresa erra é punir quem reporta. Se o funcionário fica com medo ele esconde o incidente, e incidente escondido só cresce.

Fundamentação: ISO/IEC 27002; 6.3 conscientização e treinamento; 5.1 políticas de segurança; 6.8 relato de eventos

QUESTÃO 4 - Hash e integridade

Ao baixar um software, o site fornece um "hash" (SHA-256). Explique como o uso desse hash garante a integridade do arquivo e o que um hash diferente indicaria ao usuário.

Resposta:

O hash funciona como uma impressão digital do arquivo. Se o hash que eu calculo bate com o que o site publicou, o arquivo que chegou é exatamente o mesmo que o autor colocou lá.

Eu baixo o arquivo, calculo o SHA-256 na minha máquina e comparo com o que está no site. A função sempre dá o mesmo resultado pro mesmo arquivo e qualquer mudança de um bit já muda o hash inteiro, então não existe quase igual.

Se o hash der diferente quer dizer que o arquivo mudou no caminho. Pode ter sido um download corrompido ou pode ser que alguém trocou o instalador por um com backdoor. Nos dois casos a decisão é a mesma, não instala.

Só que o hash sozinho garante integridade e não garante autenticidade. Se o atacante invadiu o site ele troca o arquivo e troca o hash junto. Por isso o ideal é o hash vir por um canal confiável ou o arquivo ter assinatura digital.

Fundamentação: ISO/IEC 27002; 8.24 uso de criptografia; Tríade CID; Integridade

QUESTÃO 5 - Classificação de informação

Uma empresa classifica seus dados em: Público, Interno e Confidencial. Relacione essa classificação com o controle de acesso e o impacto de um vazamento em cada nível.

Resposta:

O nível de classificação vem do impacto que o vazamento causa, e o controle de acesso vem do nível.

Informação pública circula livre e não precisa de controle nenhum porque ela já nasceu pra ser vista. Se vazar não acontece nada.

Interna é só pra colaborador autenticado. Se vazar causa constrangimento e expõe processo interno, mas não gera multa e nem faz perder contrato.

Confidencial é acesso mínimo, só quem precisa mesmo, com registro de quem abriu e criptografia. Se vazar dói no caixa, dá problema com a LGPD e queima a imagem da empresa. E o descarte muda junto, aqui não basta apagar, tem que sobrescrever ou triturar.

Classificar é decidir antes quanto custa perder aquele ativo, pra proteger na medida certa.

Fundamentação: ISO/IEC 27002; 5.12 classificação; 5.13 rotulagem; 5.15 controle de acesso; 8.10 exclusão de informações

QUESTÃO 6 - Ameaça, vulnerabilidade e risco

Diferencie os conceitos de Ameaça, Vulnerabilidade e Risco. Como a implementação de um firewall atua sobre esses elementos em um cenário de invasão externa?

Resposta:

Ameaça é o agente ou o evento que pode causar dano, tipo o invasor, que existe querendo eu ou não. Vulnerabilidade é a minha fraqueza que ele consegue explorar, por exemplo uma porta de administração remota aberta pra internet. E risco é a chance disso acontecer vezes o impacto que causa.

Ameaça eu não controlo, vulnerabilidade eu controlo. Se não tem vulnerabilidade pra explorar a ameaça continua existindo mas fica só na ameaça.

O firewall não age na ameaça, ele age na vulnerabilidade. Ele fecha porta, filtra serviço exposto e diminui a superfície de ataque, e com isso derruba a probabilidade. Derrubando a probabilidade o risco cai junto.

O invasor continua lá tentando. O que sobra depois do controle é o risco residual, que a empresa aceita formalmente ou trata de novo.

Fundamentação: ISO/IEC 27001; 6.1.2 avaliação e 6.1.3 tratamento de riscos; ISO/IEC 27005; 27002; 8.20 segurança de redes

QUESTÃO 7 - RTO e RPO

Após um incêndio no datacenter, a empresa ativa seu site de backup. Explique a importância do RTO (Recovery Time Objective) e do RPO (Recovery Point Objective) neste processo.

Resposta:

RTO é quanto tempo a empresa aguenta ficar parada e RPO é quanto dado ela aceita perder.

O RTO conta pra frente a partir do desastre e define quanto vai precisar investir em infraestrutura. Site quente sobe em minutos e custa caro, site frio é barato mas demora dias. O RPO conta pra trás e define de quanto em quanto tempo o backup ou a replicação tem que rodar. Se o RPO é de uma hora o backup tem que ser de hora em hora no mínimo.

Sem esses dois números definidos antes o plano de continuidade vira achismo, porque não dá pra saber se o site de backup atende. Um banco trabalha com RPO quase zero porque não pode perder transação, já uma papelaria vive tranquila com RTO de dois dias.

Fundamentação: ISO/IEC 27001; A.5.29 e A.5.30; ISO 22301 continuidade de negócio

QUESTÃO 8 - Backup que ninguém testou

Uma empresa realiza backups diários, mas nunca testou a restauração. Analise o risco envolvido e como isso impacta a garantia do princípio da Disponibilidade.

Resposta:

Backup que nunca foi restaurado não é backup, é esperança.

O problema é que a empresa só vai descobrir que a cópia está corrompida na hora do desastre, que é o pior momento possível. E as formas de dar errado são bem banais, job que falha em silêncio há meses, base que ficou fora do escopo, mídia velha, backup criptografado com uma chave que ninguém sabe onde está.

A Disponibilidade não é garantida por ter backup, ela é garantida pela restauração funcionar. Enquanto ninguém restaurou o controle só existe no papel, e ainda dá uma falsa sensação de segurança que é pior do que não ter.

A correção é fazer teste de restauração periódico, documentado e com cronômetro. O cronômetro é o que mostra o RTO real e diz se ele bate com o que foi prometido.

Fundamentação: ISO/IEC 27002; 8.13 backup de informações; 5.29 segurança durante interrupção

QUESTÃO 9 - Auditoria interna e PDCA

Qual o papel da auditoria interna na manutenção da certificação ISO 27001? Explique como o ciclo PDCA (Plan-Do-Check-Act) se aplica à Segurança da Informação.

Resposta:

A auditoria interna é o Check do PDCA. É a empresa se olhando no espelho antes do auditor externo olhar.

Ela serve pra conferir se o que está escrito na política é o que acontece de verdade no dia a dia. Certificação não é coisa que ganha uma vez e pendura na parede, ela é mantida e auditada de novo de tempos em tempos.

No ciclo fica assim. No Plan a empresa define o escopo, analisa risco, escolhe os controles e assina a Declaração de Aplicabilidade. No Do ela implementa e opera. No Check ela monitora, mede e audita. E no Act ela corrige a não conformidade, e essa correção entra como entrada do próximo Plan.

Sem o Check o SGSI vira documento morto. O achado da auditoria é o que alimenta o Act e faz o ciclo girar de verdade.

Fundamentação: ISO/IEC 27001; 9.2 auditoria interna; 9.3 análise crítica pela direção; 10 melhoria

QUESTÃO 10 - Governança e alta gestão

Relacione a Segurança da Informação com a Governança Corporativa. Por que a segurança deve ser uma preocupação da alta gestão e não apenas do departamento de TI?

Resposta:

Segurança é decisão de risco de negócio, e risco de negócio é da diretoria e não do analista.

Quem aceita risco precisa ter autoridade pra aceitar. Nenhum analista decide sozinho que a empresa vai conviver com o risco de tomar uma multa de LGPD, isso é assinatura de quem responde pela empresa.

Tem o lado prático também. Sem apoio da alta gestão a segurança perde toda disputa de orçamento e vira o setor que atrasa projeto. E tem o lado legal, porque a LGPD responsabiliza o controlador, ou seja a empresa e os dirigentes, e não o técnico que configurou o servidor.

Fora que segurança atravessa o RH na admissão e no desligamento, o Jurídico no contrato e nas cláusulas, e o Financeiro. Só a alta gestão tem alcance pra atravessar área, e por isso a ISO 27001 coloca o comprometimento da Alta Direção como requisito e não como sugestão.

Fundamentação: ISO/IEC 27001; 5.1 liderança e comprometimento; LGPD art. 42 a 45; ISO/IEC 27002; 5.4 responsabilidades da direção